Security & Privacy Disclosure, Final Report

F1 TV Android (com.formulaone.production)

A hardcoded Firebase API key exposes the production database behind a paid subscription streaming service, two separate Salesforce Marketing Cloud CRM providers and two separate PingIdentity DaVinci identity collectors initialise before consent, and Facebook App Events tracks subscription conversions before any consent signal, unresolved through 109 days and a 19-day-overdue embargo, after the company's own published privacy and security addresses bounced on every single attempt across the entire case

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, FOUR FINDINGS REMAIN UNADDRESSED

Target	Formula One Management Ltd, London, UK / Liberty Media Corporation (NYSE: FWONA/FWONK)
Package	com.formulaone.production
Platform Audited	Android, static analysis of the production APK
Initial Disclosure (R1)	2026-06-30, to privacy@formula1.com and dpo@formula1.com — bounced outright, address not found
First Confirmed Delivery	2026-07-17, to datateam@f1.com (a working address found after repeated bounces)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	4 (1 Critical, 3 High)
Correspondence	10 messages sent by RFI-IRFOS, 4 of them (2026-06-30, 2026-07-06, 2026-07-23, 2026-09-12) to privacy@formula1.com / dpo@formula1.com / press@formula1.com, every one of which bounced outright across the entire case; 6 messages to the working address datateam@f1.com (2026-07-17 through 2026-08-31), the only channel that ever delivered; 0 substantive replies ever received, 1 automated out-of-office response from a named employee
Authorities CC'd	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) and European Data Protection Supervisor (edps@europa.eu)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 5

4.1 C1: Firebase API key and production database URL hardcoded in every installed copy of the APK . . . 6

4.2 H1: Two separate Salesforce Marketing Cloud CRM providers initialise before consent . . . 6

4.3 H2: Two separate PingIdentity DaVinci identity collectors duplicate authentication infrastructure, US transfer . . . 7

4.4 H3: Facebook App Events tracks subscription conversions before consent, on a paid service with no advertising-funded justification . . . 7

5 Impact Analysis 8

6 The Complete Chain: Three Addresses That Never Worked, and a Channel Found Independently 8

7 Data Protection – Article by Article 9

8 Regulatory & Legal Landscape 9

9 Indicators of Compromise 10

10 Disclosure Timeline & Outcome 10

11 Residual Risk & Recommendations 11

Executive Summary

Formula One Management Ltd, the London-based operator of F1 TV under Liberty Media Corporation (NYSE: FWONA/FWONK, approximately 18 billion USD market cap), runs F1 TV as a paid subscription streaming service for motorsport fans. A static analysis of the production Android binary (package com.formulaone.production) found four findings, one CRITICAL and three HIGH.

A Firebase API key and the production Firebase database URL are hardcoded in every installed copy of the APK, granting third-party access to Google services billed to Formula One Management and exposing the production database endpoint directly (C1). The app declares two separate Salesforce Marketing Cloud ContentProviders, an older MCInitContentProvider and a newer SFMCSdkInitContentProvider, both initialising before the consent screen, suggesting subscriber data is written into two separate Salesforce instances, each its own undocumented EU-to-US transfer (H1). Two separate PingIdentity DaVinci CollectorRegistry entries duplicate identity-orchestration infrastructure, processing authentication behaviour, session tokens, and device fingerprinting data, and routing it to PingIdentity Corp. (Denver, Colorado, USA), a third-country transfer with no documented safeguard (H2). The Facebook SDK's FacebookInitProvider initialises before any consent signal and tracks subscription-conversion events, transmitting motorsport-subscriber behavioural data to Meta Platforms (USA) on a paid service where that behavioural profile has no connection to an advertising-funded business model (H3).

RFI-IRFOS's original disclosure, sent 30 June 2026 to privacy@formula1.com and dpo@formula1.com, CC press@formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor, bounced outright at all three Formula One addresses the same day, address not found. A resend on 6 July 2026 to the same three addresses bounced again, identically. A working channel, datateam@f1.com, was located and first used on 17 July 2026; five further messages followed there (27 July, 9 August, 15 August, 24 August, 31 August 2026), the only channel that ever delivered across the entire case. The sole response of any kind, across 10 messages and 109 days, was an automated out-of-office reply from a named Formula One employee on 9 August 2026. A further attempt to re-establish contact at the original privacy@/dpo@/press@formula1.com addresses on 12 September 2026 bounced a third time, this time as a hard block rather than an address-not-found error. Not one substantive reply was ever received, from any address, on any channel.

ID	Severity	Title
C1	CRITICAL	Firebase API key and production database URL hard-coded in every installed copy of the APK
H1	HIGH	Two separate Salesforce Marketing Cloud CRM providers initialise before consent
H2	HIGH	Two separate PingIdentity DaVinci identity collectors duplicate authentication infrastructure, US transfer
H3	HIGH	Facebook App Events tracks subscription conversions before consent, on a paid service with no advertising-funded justification

Subject & Operator Context

Formula One Management Ltd is the London-based commercial and media rights arm of Formula One, operating under Liberty Media Corporation (NYSE: FWONA/FWONK), a publicly traded US media conglomerate with a market capitalisation of approximately 18 billion USD. F1 TV is Formula One's own direct-to-consumer paid subscription streaming service, offering live race coverage, onboard cameras, and archival race footage to motorsport fans across the EU and worldwide.

Engagement Summary

RFI-IRFOS sent the original disclosure on 30 June 2026 to privacy@formula1.com and dpo@formula1.com, CC press@formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor. All three Formula One addresses bounced the same day, address not found. A resend on 6 July 2026 to the identical three addresses bounced again, identically, confirming the failure was not a one-off.

A working channel, datateam@f1.com, was located and first used on 17 July 2026, CC general@en.formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor. This channel never bounced across five further follow-ups, sent 27 July, 9 August, 15 August, 24 August, and 31 August 2026, each restating the open findings and the days elapsed. The sole response received across the entire case, on any channel, was an automated out-of-office reply from a named Formula One employee on 9 August 2026, confirming a live human mailbox exists at that address without addressing a single finding on its merits. A further attempt on 12 September 2026 to re-establish contact at the original privacy@/dpo@/press@formula1.com addresses, in parallel with the working channel, bounced a third time, now as an explicit block rather than an address-not-found error, confirming those three addresses never functioned at any point across the full 109-day case. Not one message, on either channel, ever received a substantive human reply.

Findings

C1: Firebase API key and production database URL hardcoded in every installed copy of the APK

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N, 8.7) — third-party access to Google services billed to Formula One, and the production database endpoint, exposed in every copy of a publicly distributed app

```
google_api_key: AIzaSyAZiGqWDG7SfXNZSzzWZ__WvpWhgj6VXo0
firebase_database_url: https://formula-1-1236.firebaseio.com

Present in: every installed copy of the production APK
Granted access: Google services billed to Formula One Management Ltd
```

Impact: A Google API key and the production Firebase database URL are hardcoded in res/values/strings.xml and present in every installed copy of the F1 TV APK (google_api_key: AIzaSyAZiGqWDG7SfXNZSzzWZ__WvpWhgj6VXo0, firebase_database_url: https://formula-1-1236.firebaseio.com). The API key grants third-party access to Google services billed to Formula One Management, exposing the operator to quota-exhaustion denial-of-service costs, and the database URL exposes the production database endpoint directly to anyone who extracts the string from the public binary.

H1: Two separate Salesforce Marketing Cloud CRM providers initialise before consent

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — subscriber data written into two separate Salesforce instances before any consent interaction, each its own undocumented US transfer

```
com.salesforce.marketingcloud.MCInitContentProvider (legacy SFMC SDK)
com.salesforce.android.sfmc.SFMCSdkInitContentProvider (SFMC Mobile Push SDK v2)

Both initialise: before the consent screen
Data suggested in scope: subscription tier, viewing behaviour, payment status
```

Impact: F1 TV declares two separate Salesforce Marketing Cloud ContentProviders, com.salesforce.marketingcloud.MCInitContentProvider (legacy SFMC SDK) and com.salesforce.android.sfmc.SFMCSdkInitContentProvider (SFMC Mobile Push SDK v2), both initialising via the ContentProvider mechanism before the user reaches the consent screen. Salesforce Marketing Cloud is a full-stack CRM platform covering push notifications, email journeys, behavioural analytics, and subscriber segmentation. Two parallel SFMC integrations on a single subscription streaming service suggest subscriber data, subscription tier, viewing behaviour, and payment status, is written into two separate Salesforce instances, each constituting an independent EU-to-US data transfer requiring its own documented Art. 44-49 safeguard.

H2: Two separate PingIdentity DaVinci identity collectors duplicate authentication infrastructure, US transfer

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — authentication behaviour, session tokens, and device fingerprinting routed to a US identity vendor via two parallel, architecturally redundant collectors

```
com.pingidentity.orchestrate.core.CollectorRegistry (x2 entries)
Operator: PingIdentity Corp., Denver, Colorado, USA
Data category: login behaviour, session tokens, device fingerprinting parameters
Art. 44-49 safeguard documented: none identified
```

Impact: Two separate com.pingidentity.orchestrate.core.CollectorRegistry entries are present in the production binary, both from PingIdentity DaVinci, an identity orchestration platform operated by PingIdentity Corp. (Denver, Colorado, USA). DaVinci processes login behaviour, session tokens, and device fingerprinting parameters. Two separate CollectorRegistry entries on a single app are architecturally unusual and increase the data exposure surface, authentication and device data flows to two separate collector endpoints rather than one, with no documented Art. 44-49 safeguard for either EU-to-US transfer.

H3: Facebook App Events tracks subscription conversions before consent, on a paid service with no advertising-funded justification

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 5.3) — motorsport-subscriber behavioural data transmitted to Meta before consent, on a paid subscription service with no advertising-revenue rationale for the tracking

```
com.facebook.internal.FacebookInitProvider (ContentProvider, auto-init before consent)
com/facebook/appevents (subscription conversion tracking)
Transfer destination: Meta Platforms, Inc., USA
Business model: paid subscription, no advertising-revenue rationale for this tracking
```

Impact: F1 TV is a paid subscription streaming service with no advertising-funded business model. The Facebook SDK's com.facebook.internal.FacebookInitProvider ContentProvider initialises before any consent signal is collected, and Facebook App Events tracks subscription-conversion flows, transmitting subscriber behavioural data to Meta Platforms (USA). Motorsport subscription interest, viewing patterns, and fan-engagement data are detailed profile categories that Meta combines with its broader user graph, with no Art. 6(1) legal basis disclosed and no documented Art. 44-49 safeguard for the transfer.

Impact Analysis

This report's CRITICAL finding, C1, is a straightforward hardening failure with a direct operational cost to Formula One itself, a hardcoded key billed to the company's own Google account, rather than a complex privacy-architecture question. The three HIGH findings share a common thread: in each case, a mechanism that is architecturally redundant (two Salesforce providers, two PingIdentity collectors) or contextually unjustified (advertising-conversion tracking on a paid, non-advertising-funded service) initialises before the user has any opportunity to consent. A subscriber paying Formula One directly for F1 TV has no advertising-funded-service rationale available to explain why their viewing behaviour is tracked for Meta's ad platform, or why their subscription and authentication data each flow to two separate instances of two different US vendors rather than one.

What ties all four findings together procedurally is the correspondence record itself: the three addresses Formula One's own privacy disclosures point to, privacy@formula1.com, dpo@formula1.com, and press@formula1.com, never worked, not once, across four separate attempts spanning the entire 109-day case. A working channel existed only because RFI-IRFOS located one independently; the only response that channel ever produced was an automated out-of-office notice.

The Complete Chain: Three Addresses That Never Worked, and a Channel Found Independently

Step 1 – First attempt, outright failure: RFI-IRFOS sends the full disclosure on 30 June 2026 to privacy@formula1.com and dpo@formula1.com, CC press@formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor. All three Formula One addresses bounce the same day, address not found.

Step 2 – Resend, identical failure: RFI-IRFOS resends the complete disclosure on 6 July 2026 to the same three addresses. All three bounce again, identically.

Step 3 – A working channel located independently: RFI-IRFOS locates and first uses datateam@f1.com on 17 July 2026, CC general@en.formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor. This channel delivers without a bounce.

Step 4 – A third attempt at the original addresses, in parallel: On 23 July 2026, RFI-IRFOS also attempts privacy@formula1.com and dpo@formula1.com once more. Both bounce again.

Step 5 – Follow-ups continue on the working channel: RFI-IRFOS sends further follow-ups to datateam@f1.com on 27 July, 9 August, 15 August, 24 August, and 31 August 2026, each restating the four findings and the days elapsed.

Step 6 – The only response of the entire case: On 9 August 2026, an automated out-of-office reply arrives from a named Formula One employee, confirming a live human mailbox exists at the working address, without addressing any finding.

Step 7 – A fourth and final attempt at the dead addresses: On 12 September 2026, RFI-IRFOS attempts privacy@formula1.com, dpo@formula1.com, and press@formula1.com a fourth time, now in parallel with continued silence on the working channel. All three bounce a third distinct way, as an explicit block rather than an address-not-found error, closing out any possibility that those three addresses ever functioned across the full case.

Step 8 – Embargo reached and passed: The embargo, stated as 28 September 2026 from the very first message onward and never revised, passes with all four findings unaddressed.

Step 9 – Publication: This report publishes 19 days after the embargo date. Across 109 days and 10 messages sent on two separate channels, the only response Formula One's systems or staff produced was a single automated out-of-office notice.

Data Protection – Article by Article

Art. 32(1)(b), Art. 25 GDPR – Security of processing and data protection by design: C1's hardcoded Firebase key and production database URL fall short of the technical measures and by-design minimisation these provisions require.

Art. 7, Art. 13, Art. 28, Art. 44-49 GDPR – Consent, transparency, processor agreements, and third-country transfer: H1's dual Salesforce Marketing Cloud initialisation occurs before consent, with no disclosed legal basis, no named data-processing agreement, and no documented transfer safeguard for either of the two Salesforce instances in scope.

Art. 44-49, Art. 5(1)(c), Art. 13 GDPR – Third-country transfer, data minimisation, and transparency: H2's duplicate PingIdentity DaVinci collectors have no documented Art. 44-49 safeguard and no disclosed justification for the architectural redundancy itself.

Art. 7, Art. 44-49, Art. 6(1) GDPR – Consent, third-country transfer, and lawfulness of processing: H3's Facebook App Events tracking occurs before consent, with no Art. 6(1) legal basis disclosed for tracking paid subscribers for an advertising platform their subscription itself does not fund.

Regulatory & Legal Landscape

Formula One Management Ltd operates from London, United Kingdom, under Liberty Media Corporation, a publicly traded US media conglomerate (NYSE: FWONA/FWONK). The Austrian Datenschutzbehoerde and the European Data Protection Supervisor were both CC'd on this disclosure throughout, given RFI-IRFOS's Austrian registration and F1 TV's EU-wide subscriber base.

Fine exposure under GDPR: Art. 83(5) applies to the Art. 7, Art. 13, and Art. 44-49 transparency, consent, and third-country-transfer issues in H1, H2, and H3, up to EUR 20,000,000 or 4% of total worldwide annual turnover. Art. 83(4) applies to the Art. 32 and Art. 25 security-and-design issue in C1, up to EUR 10,000,000 or 2% of total worldwide annual turnover. A disclosure that could not reach a single working address at the company's own stated privacy, data-protection, or press contacts across four separate attempts and 109 days is itself a fact a regulator assessing Art. 12 responsiveness obligations is likely to find relevant, independent of the four technical findings.

Indicators of Compromise

The following identifiers, SDK packages, and manifest declarations were extracted from the production APK via static analysis only. No Formula One servers, accounts, or infrastructure were probed.

```
C1 -- google_api_key: AIzaSyAZiGqWDG7SfXNZSzzWZ__WvpWhgj6VXo0
  firebase_database_url: https://formula-1-1236.firebaseio.com

H1 -- com.salesforce.marketingcloud.MCInitContentProvider
  com.salesforce.android.sfmc.SFMCSdkInitContentProvider

H2 -- com.pingidentity.orchestrate.core.CollectorRegistry (x2 entries)

H3 -- com.facebook.internal.FacebookInitProvider
  com/facebook/appevents
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to privacy@formula1.com and dpo@formula1.com, CC press@formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor. All three bounce, address not found.

2026-07-06 Resend to the identical three addresses. All three bounce again, identically.

2026-07-17 First confirmed delivery, to datateam@f1.com, CC general@en.formula1.com, the Austrian Datenschutzbehoerde, and the European Data Protection Supervisor.

2026-07-23 A further attempt at privacy@formula1.com and dpo@formula1.com. Both bounce again.

2026-07-27 Follow-up to datateam@f1.com, 10 days since the working channel was found.

2026-08-09 Follow-up to datateam@f1.com. An automated out-of-office reply arrives from a named Formula One employee the same day, the only response of the entire case.

2026-08-15 Follow-up to datateam@f1.com, 47 days since the original disclosure.

2026-08-24 Follow-up to datateam@f1.com, 56 days since the original disclosure.

2026-08-31 Final follow-up to datateam@f1.com, 7 days after the previous message.

2026-09-12 A fourth and final attempt at privacy@formula1.com, dpo@formula1.com, and press@formula1.com. All three bounce a third distinct way, as an explicit block.

2026-09-28 Embargo date reached, as stated from the first message onward. Correspondence record: 10 RFI-IRFOS messages across two channels, 7 bounces at the three dead addresses, 1 automated out-of-office reply, 0 substantive replies.

2026-10-17 This report published, 19 days after the embargo date. All four findings confirmed unaddressed on the basis of the correspondence record.

Residual Risk & Recommendations

C1 – Immediate: rotate the hardcoded Firebase API key and remove the production database URL from the client binary, and audit Firebase security rules for the exposed database.

H1 – Immediate: consolidate to a single Salesforce Marketing Cloud integration, or document separate Art. 28 processor agreements and Art. 44-49 transfer safeguards for each of the two instances currently in use, and gate both behind consent.

H2 – Near-term: consolidate the two PingIdentity DaVinci CollectorRegistry entries into one, document the technical justification if genuine redundancy is required, and document an Art. 44-49 safeguard for the transfer.

H3 – Near-term: gate Facebook App Events behind consent, and reassess whether adverti sing-conversion tracking has any legitimate purpose on a paid subscription service with no advertising-funded revenue stream.

Across all findings: review why privacy@formula1.com, dpo@formula1.com, and press@formula1.com, the addresses a data subject or researcher would reasonably expect to use to reach Formula One on a data-protection matter, failed on every one of four attempts across 109 days, since the same failure would equally block a subscriber attempting to exercise their own GDPR rights.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Formula One servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF F1TV-2026-R1-001.